

Private biometrics is a form of encrypted biometrics, also called privacy-preserving biometric authentication methods, in which the biometric measurement is cryptographically processed such that no data stored in a data base can be (mis-) used to recover information about the human subject.

Biometrics, in contrast to user pass words, are noisy data that slightly differ from measurement to measurement. Small variations input data prevent the use of traditional encryption or hashing.

The introduction of a fuzzy extractor was a pioneering contribution to nonetheless apply cryptographic techniques to inherently noisy biometric data.

Helper Data Schemes

Fuzzy Commitments were proposed as "Helper Data Schemes" for storing biometric templates.

A helper data system (HDS) is a cryptographic primitive designed to extract a consistent, high-entropy secret string (like a cryptographic key) from inherently noisy data, such as a biometric measurement. The primary purpose of an HDS is to enable reliable biometric authentication or identification while preserving privacy. It achieves this by ensuring that the stored data does not reveal sensitive information about the original biometric template or the extracted secret key to an attacker, even if the database is compromised by an insider attack. The data base stores a cryptographic hash of the quantized biometric measurement and the "helper data", in which the helper data is used to bias the quantization process. According to an information theoretical proof, helper data reveal no information about the biometric. The cryptograph strength of the hash function ensures that it is not computationally feasible to reconstruct the original nor any biometric features from the hash.

Homomorphic Encryption

According to one other possible approach, the biometric payload is a one-way, homomorphically encrypted feature vector that can be 0.05% the size of the original biometric template and can be searched with full accuracy, speed and privacy. The feature vector's homomorphic encryption allows search and match to be conducted in polynomial time on an encrypted dataset and the search result is returned as an encrypted match. One or more computing devices may use an encrypted feature vector to verify an individual person (1:1 verify) or identify an individual in a datastore (1:many identify) without storing, sending or receiving plaintext biometric data within or between computing devices or any other entity. The purpose of private biometrics is to allow a person to be identified or authenticated while guaranteeing individual privacy and fundamental human rights by only operating on biometric data in the encrypted space. Some private biometrics include fingerprint authentication methods, face authentication methods, and identity-matching algorithms according to bodily features. Private biometrics are constantly evolving based on the changing nature of privacy needs, identity theft, and biotechnology.

Background

Biometric security strengthens user authentication but, until recently, also implied important risks to personal privacy. Indeed, while compromised passwords can be easily replaced and are not personally identifiable information (PII), biometric data is considered highly sensitive due to its personal nature, unique association with users, and the fact that compromised biometrics (biometric templates) cannot be revoked or replaced. Private biometrics have been developed to address this challenge. Private Biometrics provide the necessary biometric authentication while simultaneously minimizing user's privacy exposure through the use of one-way, fully homomorphic encryption.

The Biometric Open Protocol Standard, IEEE 2410-2018, was updated in 2018 to include private biometrics and stated that the one-way fully homomorphic encrypted feature vectors,

“...bring a new level of consumer privacy assurance by keeping biometric data encrypted both at rest and in transit.” The Biometric Open Protocol Standard (BOPS III) also noted a key benefit of private biometrics was the new standard allowed for simplification of the API since the biometric payload was always one-way encrypted and therefore had no need for key management.

Fully homomorphic cryptosystems for biometrics

Historically, biometric matching techniques have been unable to operate in the encrypted space and have required the biometric to be visible (unencrypted) at specific points during search and match operations. This decrypt requirement made large-scale search across encrypted biometrics (“1:many identify”) infeasible due to both significant overhead issues (e.g. complex key management and significant data storage and processing requirements) and the substantial risk that the biometrics were vulnerable to loss when processed in plaintext within the application or operating system (see FIDO Alliance, for example).

Biometric security vendors complying with data privacy laws and regulations (including Apple FaceID, Samsung, Google) therefore focused their efforts on the simpler 1:1 verify problem and were unable to overcome the large computational demands required for linear scan to solve the 1:many identify problem.

Today, private biometric cryptosystems overcome these limitations and risks through the use of one-way, fully homomorphic encryption. This form of encryption allows computations to be carried out on ciphertext, allows the match to be conducted on an encrypted dataset without decrypting the reference biometric, and returns an encrypted match result. Matching in the encrypted space offers the highest levels of accuracy, speed and privacy and eliminates the risks associated with decrypting biometrics.

Accuracy: same as plaintext (99%)

The private biometric feature vector is much smaller (0.05% the size of the original biometric template) but yet maintains the same accuracy as the original plaintext reference biometric. In testing using Google's unified embedding for face recognition and clustering CNN ("Facenet"), Labeled Faces in the Wild (LFW) (source), and other open source faces, private biometric feature vectors returned the same accuracy as plaintext facial recognition. Using an 8MB facial biometric, one vendor reported an accuracy rate of 98.7%. The same vendor reported accuracy increased to 99.99% when using three 8MB facial biometrics and a vote algorithm (best two out of 3) to predict.

As the quality of the facial biometric image declined, accuracy degraded very slowly. For 256kB facial images (3% the quality of an 8MB picture), the same vendor reported 96.3% accuracy and that the neural network was able to maintain similar accuracy through boundary conditions including extreme cases of light or background.

Speed: polynomial search (same as plaintext)

The private biometric feature vector is 4kB and contains 128 floating point numbers. In contrast, plaintext biometric security instances (including Apple Face ID) currently use 7MB to 8MB reference facial biometrics (templates). By using the much smaller feature vector, the resulting search performance is less than one second per prediction using a datastore of 100 million open source faces ("polynomial search"). The private biometric test model used for these results was Google's unified embedding for face recognition and clustering CNN ("Facenet"), Labeled Faces in the Wild (LFW) (source), and other open source faces.

Privacy: full compliance with privacy regulations worldwide

As with all ideal one-way cryptographic hash functions, decrypt keys do not exist for private biometrics so it is infeasible to generate the original biometric message from the private biometric feature vector (its hash value) except by trying all possible messages. Unlike

passwords, however, no two instances of a biometric are exactly the same or, stated in another way, there is no constant biometric value, so a brute force attack using all possible faces would only produce an approximate (fuzzy) match. Privacy and fundamental human rights are therefore guaranteed.

Specifically, the private biometric feature vector is produced by a one-way cryptographic hash algorithm that maps plaintext biometric data of arbitrary size to a small feature vector of a fixed size (4kB) that is mathematically impossible to invert. The one-way encryption algorithm is typically achieved using a pre-trained convolutional neural network (CNN), which takes a vector of arbitrary real-valued scores and squashes it to a 4kB vector of values between zero and one that sum to one. It is mathematically impossible to reconstruct the original plaintext image from a private biometric feature vector of 128 floating point numbers.

One-way encryption, history and modern use

One-way encryptions offer unlimited privacy by containing no mechanism to reverse the encryption and disclose the original data. Once a value is processed through a one-way hash, it is not possible to discover the original value (hence the name “one-way”).

History

The first one-way encryptions were likely developed by James H. Ellis, Clifford Cocks, and Malcolm Williamson at the UK intelligence agency GCHQ during the 1960s and 1970s and were published independently by Diffie and Hellman in 1976 (History of cryptography). Common modern one-way encryption algorithms, including MD5 (message digest) and SHA-512 (secure hash algorithm) are similar to the first such algorithms in that they also contain no mechanism to disclose the original data. The output of these modern one-way encryptions offer high privacy but are not homomorphic, meaning that the results of the one-way encryptions do not allow high order math operations (such as match). For example, we cannot use two SHA-512

sums to compare the closeness of two encrypted documents. This limitation makes it impossible for these one-way encryptions to be used to support classifying models in machine learning—or nearly anything else.

Modern use

The first one-way, homomorphically encrypted, Euclidean-measurable feature vector for biometric processing was proposed in a paper by Streit, Streit and Suffian in 2017.

In this paper, the authors theorized and also demonstrated using a small sample size ($n=256$ faces) that (1) it was possible to use neural networks to build a cryptosystem for biometrics that produced one-way, fully homomorphic feature vectors composed of normalized floating-point values; (2) the same neural network would also be useful for 1:1 verification (matching); and (3) the same neural network would not be useful in 1:many identification tasks since search would occur in linear time (i.e. non polynomial). The paper's first point was (in theory) later shown to be true, and the papers first, second and third points were later shown to be true only for small samples but not for larger samples.

A later tutorial (blog posting) by Mandel in 2018 demonstrated a similar approach to Streit, Streit and Suffian and confirmed using a Frobenius 2 distance function to determine the closeness of two feature vectors. In this posting, Mandel used a Frobenius 2 distance function to determine the closeness of two feature vectors and also demonstrated successful 1:1 verification. Mandel did not offer a scheme for 1:many identification as this method would have required a non polynomial full linear scan of the entire database. The Streit, Streit and Suffian paper attempted a novel “banding” approach for 1:many identification in order to mitigate the full linear scan requirement, but it is now understood that this approach produced too much overlap to help in identification.

First production implementation

The first claimed commercial implementation of private biometrics, Private.id, was published by Private Identity, LLC in May 2018 by using the same method to provide 1:many identification in polynomial time across a large biometrics database (100 million faces).

On the client device, Private.id transforms each reference biometric (template) into a one-way, fully homomorphic, Euclidean-measurable feature vector using matrix multiplication from the neural network that may then be stored locally or transmitted. The original biometric is deleted immediately after the feature vector is computed or, if the solution is embedded in firmware, the biometric is transient and never stored. Once the biometric is deleted, it is no longer possible to lose or compromise the biometric.

The Private.id feature vector can be used in one of two ways. If the feature vector is stored locally, it may be used to compute 1:1 verification with high accuracy (99% or greater) using linear mathematics. If the feature vector is also stored in a Cloud, the feature vector may also be used as input for a neural network to perform 1:many identification with the same accuracy, speed and privacy as the original plaintext reference biometric (template).

Compliance

Private biometrics use the following two properties in deriving compliance with biometric data privacy laws and regulations worldwide. First, the private biometrics encryption is a one-way encryption, so loss of privacy by decryption is mathematically impossible and privacy is therefore guaranteed. Second, since no two instances of a biometric are exactly the same or, stated in another way, there is no constant biometric value, the private biometrics one-way encrypted feature vector is Euclidean Measureable in order to provide a mechanism to determine a fuzzy match in which two instances of the same identity are “closer” than two instances of a different identity.

IEEE Biometric Open Protocol Standard (BOPS III)

The IEEE 2410-2018 Biometric Open Protocol Standard was updated in 2018 to include private biometrics. The specification stated that one-way fully homomorphic encrypted feature vectors, “bring a new level of consumer privacy assurance by keeping biometric data encrypted both at rest and in transit.” IEEE 2410-2018 also noted a key benefit of private biometrics is that the new standard allows for simplification of the API since the biometric payload is always one-way encrypted and there is no need for key management.

Discussion: passive encryption and data security compliance

Private biometrics enables passive encryption (encryption at rest), the most difficult requirement of the US Department of Defense Trusted Computer System Evaluation Criteria (TCSEC). No other cryptosystem or method provides operations on rested encrypted data, so passive encryption—an unfulfilled requirement of the TCSEC since 1983, is no longer an issue. Private biometrics technology is an enabling technology for applications and operating systems—but itself does not directly address—the auditing and constant protection concepts introduced in the TCSEC.

US DoD Standard Trusted Computer System Evaluation Criteria (TCSEC)

Private biometrics, as implemented in a system that conforms to IEEE 2410-2018 BOPS III, satisfies the privacy requirements of the US Department of Defense Standard Trusted Computer System Evaluation Criteria (TCSEC). The TCSEC sets the basic requirements for assessing the effectiveness of computer security controls built into a computer system (“Orange Book, section B1”). Today, the applications and operating systems contain features that comply with TCSEC levels C2 and B1 except they lack homomorphic encryption and so do not process data encrypted at rest. We typically, if not always, obtained waivers, because there

was not a known work around. Adding private biometrics to these operating systems and applications resolves this issue.

For example, consider the case of a typical MySQL database. To query MySQL in a reasonable period of time, we need data that maps to indexes that maps to queries that maps to end user data. To do this, we work with plaintext. The only way to encrypt this is to encrypt the entire data store, and to decrypt the entire data store, prior to use. Since data use is constant, the data is never encrypted. Thus, in the past we would apply for waivers because there was no known work around. Now using private biometrics, we can match and do operations on data that is always encrypted.

Multiple Independent Levels of Security/Safety (MILS) architecture

Private biometrics, as implemented in a system that conforms to IEEE 2410-2018 BOPS III, comply with the standards of the Multiple Independent Levels of Security/Safety (MILS) architecture. MILS builds on the Bell and La Padula theories on secure systems that represent the foundational theories of the US DoD Standard Trusted Computer System Evaluation Criteria (TCSEC), or the DoD "Orange Book." (See paragraphs above.)

Private biometrics' high-assurance security architecture is based on the concepts of separation and controlled information flow and implemented using only mechanisms that support trustworthy components, thus the security solution is non-bypassable, evaluable, always invoked and tamper proof. This is achieved using the one-way encrypted feature vector, which elegantly allows only encrypted data (and never stores or processes plaintext) between security domains and through trustworthy security monitors.

Specifically, private biometrics systems are:

Non-bypassable, as plaintext biometrics cannot use another communication path, including lower level mechanisms, to bypass the security monitor since the original biometric is

transient at inception (e.g. the biometric template acquired by the client device exists only for a few seconds at inception and then is deleted or never stored).

Evaluable in that the feature vectors are modular, well designed, well specified, well implemented, small and of low complexity.

Always-invoked, in that each and every message is always one-way encrypted independent of security monitors.

Tamperproof in that the feature vector's one-way encryption prevents unauthorized changes and does not use systems that control rights to the security monitor code, configuration and data.

History

Implicit authentication and private equality testing

Unsecure biometric data are sensitive due to their nature and how they can be used. Implicit authentication is a common practice when using passwords, as a user may prove knowledge of a password without actually revealing it. However, two biometric measurements of the same person may differ, and this fuzziness of biometric measurements renders implicit authentication protocols useless in the biometrics domain.

Similarly, private equality testing, where two devices or entities want to check whether the values that they hold are the same without presenting them to each other or to any other device or entity, is well practiced and detailed solutions have been published. However, since two biometrics of the same person may not be equal, these protocols are also ineffective in the biometrics domain. For instance, if the two values differ in τ bits, then one of the parties may need to present 2^τ candidate values for checking.

Homomorphic encryption

Prior to the introduction of private biometrics, biometric techniques required the use of

plaintext search for matching so each biometric was required to be visible (unencrypted) at some point in the search process. It was recognized that it would be beneficial to instead conduct matching on an encrypted dataset.

Encrypt match is typically accomplished using one-way encryption algorithms, meaning that given the encrypted data, there is no mechanism to get to the original data. Common one-way encryption algorithms are MD5 and SHA-512. However, these algorithms are not homomorphic, meaning that there is no way to compare the closeness of two samples of encrypted data, and thus no means to compare. The inability to compare renders any form of classifying model in machine learning untenable.

Homomorphic encryption is a form of encryption that allows computations to be carried out on ciphertext, thus generating an encrypted match result. Matching in the encrypted space using a one-way encryption offers the highest level of privacy. With a payload of feature vectors one-way encrypted, there is no need to decrypt and no need for key management.

A promising method of homomorphic encryption on biometric data is the use of machine learning models to generate feature vectors. For black-box models, such as neural networks, these vectors can not by themselves be used to recreate the initial input data and are therefore a form of one-way encryption. However, the vectors are euclidean measurable, so similarity between vectors can be calculated. This process allows for biometric data to be homomorphically encrypted.

For instance if we consider facial recognition performed with the Euclidean Distance, when we match two face images using a neural network, first each face is converted to a float vector, which in the case of Google's FaceNet, is of size 128. The representation of this float vector is arbitrary and cannot be reverse-engineered back to the original face. Indeed, the matrix multiplication from the neural network then becomes the vector of the face, is Euclidean measurable but unrecognizable, and cannot map back to any image.

Prior approaches used to solve private biometrics

Prior to the availability of private biometrics, research focused on ensuring the prover's biometric would be protected against misuse by a dishonest verifier through the use of partially homomorphic data or decrypted(plaintext) data coupled with a private verification function intended to shield private data from the verifier. This method introduced a computational and communication overhead which was computationally inexpensive for 1:1 verification but proved infeasible for large 1:many identification requirements.

From 1998 to 2018 cryptographic researchers pursued four independent approaches to solve the problem: cancelable biometrics, BioHashing, Biometric Cryptosystems, and two-way partially homomorphic encryption.

Feature transformation approach

The feature transformation approach “transformed” biometric feature data to random data through the use of a client-specific key or password. Examples of this approach included biohashing and cancelable biometrics. The approach offered reasonable performance but was found to be insecure if the client-specific key was compromised.

Cancelable Biometrics

The first use of indirect biometric templates (later called cancelable biometrics) was proposed in 1998 by Davida, Frankel and Matt. Three years later, Ruud Bolle, Nilini Ratha and Jonathan Connell, working in IBM's Exploratory Computer Vision Group, proposed the first concrete idea of cancelable biometrics.

Cancelable biometrics were defined in these communications as biometric templates that were unique for every application and that, if lost, could be easily cancelled and replaced. The solution was (at the time) thought to provide higher privacy levels by allowing multiple templates to be associated with the same biometric data by storing only the transformed (hashed) version of the biometric template. The solution was also promoted for its ability to

prevent linkage of the user's biometric data across various databases since only a transformed version of the biometric template (and not the unencrypted (plaintext) biometric template) was stored for later use.

Cancelable biometrics were deemed useful because of their diversity, reusability and one-way encryption (which, at the time, was referred to as a one-way transformation). Specifically, no cancellable template could be used in two different applications (diversity); it was straightforward to revoke and reissuance a cancellable template in the event of compromise (reusability); and the one-way hash of the template prevented recovery of sensitive biometric data. Finally, it was postulated that the transformation would not deteriorate accuracy.

BioHashing

Research into cancelable biometrics moved into BioHashing by 2004. The BioHashing feature transformation technique was first published by Jin, Ling and Goh and combined biometric features and a tokenized (pseudo-) random number (TRN). Specifically, BioHash combined the biometric template with a user-specific TRN to produce a set of non-invertible binary bit strings that were thought to be irreproducible if both the biometric and the TRN were not presented simultaneously.

Indeed, it was first claimed that the BioHashing technique had achieved perfect accuracy (equal error rates) for faces, fingerprints and palm prints, and the method gained further traction when its extremely low error rates were combined with the claim that its biometric data was secure against loss because factoring the inner products of biometrics feature and TRN was an intractable problem.

By 2005, however, researchers Cheung and Kong (Hong Kong Polytechnic and University of Waterloo) asserted in two journal articles that BioHashing performance was actually based on the sole use of TRN and conjectured that the introduction of any form of biometric become meaningless since the system could be used only with the tokens. These researchers also

reported that the non-invertibility of the random hash would deteriorate the biometric recognition accuracy when the genuine token was stolen and used by an impostor ("the stolen-token scenario").

Biometric cryptosystem approach

Biometric cryptosystems were originally developed to either secure cryptographic keys using biometric features ("key-biometrics binding") or to directly generate cryptographic keys from biometric features. Biometric cryptosystems used cryptography to provide the system with cryptographic keys protection and biometrics to provide the system with dynamically generated keys to secure the template and biometric system.

The acceptance and deployment of biometric cryptosystem solutions was constrained, however, by the fuzziness related with biometric data. Hence, error correction codes (ECCs), including includes fuzzy vault and fuzzy commitment, were adopted to alleviate the fuzziness of the biometric data. This overall approach proved impractical, however, due to the need for accurate authentication and suffered from security issues due to its need for strong restriction to support authentication accuracy.

Future research on biometric cryptosystems is likely to focus on a number of remaining implementation challenges and security issues involving both the fuzzy representations of biometric identifiers and the imperfect nature of biometric feature extraction and matching algorithms. And, unfortunately, since biometric cryptosystems can, at the current time, be defeated using relatively simple strategies leveraging both weaknesses of the current systems (the fuzzy representations of biometric identifiers and the imperfect nature of biometric feature extraction and matching algorithms), it is unlikely that these systems will be able to deliver acceptable end-to-end system performance until suitable advances are achieved.

Two-way partially homomorphic encryption approach

The two-way partially homomorphic encryption method for private biometrics was similar to the today's private biometrics in that it offered protection of biometric feature data through the use of homomorphic encryption and measured the similarity of encrypted feature data by metrics such as the Hamming and the Euclidean distances. However, the method was vulnerable to data loss due to the existence of secret keys that were to be managed by trusted parties. Widespread adoption of the approach also suffered from the encryption schemes' complex key management and large computational and data storage requirements.

See also

[Homomorphic encryption](#)

[Identity management](#)

External links

[BOP - Biometrics Open Protocol](#)

[Fidoalliance.org](#)

[LFWcrop Face Dataset](#)

[Cancelable biometrics](#)

[EER - equal error rate](#)

[Technovelgy.com, Biometric Match](#)

== References ==